

Audit projet — santé, risques & gouvernance

Manager / Chef de projet / Direction

Projet	CleanUx / brio — marketplace multi-métiers (Laravel 12 + apps mobiles Expo)
Destinataire	Manager / Chef de projet / Direction
Date d'audit	24 juin 2026
Référence	Réactualisation de l'audit plateforme du 8 juin 2026
Confidentialité	Document interne — confidentiel

Légende sévérité : ● Critique · ● Élevé · ● Moyen · ● Faible · ● Sain / Corrigé

1. Résumé exécutif

CleanUx est une marketplace de services multi-métiers (backend Laravel 12 + deux apps mobiles Expo), d'une **ambition fonctionnelle considérable** (~80 domaines de services, 50+ modules annoncés), développée à un **rythme intense sur ~2 mois**.

Le projet est **techniquement crédible et a réagi sérieusement à l'audit du 8 juin** : les risques critiques (double-paiement, droit à l'oubli, faille d'accès) sont corrigés et **tracés**. Mais du point de vue **pilotage**, deux risques dominant et ne sont pas techniques :

1. **Dépendance à une seule personne (bus factor = 1)** — risque structurel n°1.
2. **Écart entre le discours « production-ready » et la réalité** « pas encore validée en conditions réelles ».

Verdict : excellent MVP avancé, réactif et bien outillé, mais **pas encore mûr pour un go-live commercial** — non à cause de défauts techniques bloquants, mais à cause de risques de **gouvernance** et d'une **validation terrain (E2E, charge, conformité prouvée) inachevée**. Santé globale estimée : **~6,5 / 10**.

2. Constats de pilotage

2.1 ● Bus factor de 1 : un seul développeur sur tout le projet

L'historique git montre **un seul contributeur** (~600 commits), aucune revue par un pair (les merges sont des auto-merges).

- **Impact business** : si cette personne devient indisponible, le projet est **à l'arrêt total**. Aucune connaissance partagée, aucune redondance. La valeur de l'actif est entièrement adossée à un individu.
- **Recommandation** : avant tout engagement commercial ou levée — (a) documenter/formaliser un transfert de connaissance ; (b) recruter ou associer **un second développeur senior** ; (c) sécuriser contractuellement l'accès au code, aux comptes (Stripe, EAS, cloud) et aux secrets.

2.2 ● Écart promesse / réalité : le README survend l'état

Affirmation README	Réalité constatée
« Laravel 11.53 »	Laravel 12.62 installé
« 2116 tests verts »	~660 fichiers / chiffres incohérents entre documents
« 50+ modules production-ready »	Audit interne : readiness 7/10 , go-live conditionné à des tests E2E non faits
Nom « CleanUx »	Package nommé brio/marketplace

- **Impact** : un décideur (investisseur, client B2B, partenaire) qui lit le README conclut que le produit est livrable immédiatement — ce que les audits internes contredisent. Les incohérences (version, double nom de marque) trahissent un **manque de rigueur dans la communication d'état** et exposent à une perte de crédibilité, voire à un risque juridique si « production-ready » figure dans une offre.
- **Recommandation** : **bannir « production-ready »** tant que les critères de go-live ne sont pas remplis ; aligner README/CHANGELOG/checklists sur des chiffres vérifiés ; trancher le nom de marque.

2.3 ● Réaction à l'audit : sérieuse et traçable (point positif majeur)

Les findings critiques/élevés du 8 juin sont corrigés dans le code, et **12 commits portent un tag explicite** reliant le correctif au finding (`fix(audit-high): ...`). Un document `AUDIT-QUARANTINE-BATCH.md` liste les 12 findings volontairement non corrigés (car destructifs) avec un chemin sûr — preuve d'une **gestion consciente du risque**.

- **Recommandation** : capitaliser sur cette pratique (lien commit ↔ finding) ; planifier le sign-off des 12 items en quarantaine avant go-live.

2.4 ● Dette technique structurelle : ralentit la livraison et bloque l'onboarding

- Baseline d'analyse statique de **~3 130 erreurs gelées** (invisible, le CI passe au vert sans les traiter).
- Coexistence **v2/legacy** non finalisée (deux chemins à maintenir) ; 204 migrations dont 19-21 « fix/round ».
- `CLEANUP_PLAN_PRODUCTION.md` explicitement marqué « **ne pas lancer en autonome** » et **non exécuté**.
- **Impact** : chaque fonctionnalité coûte plus cher, le risque de bug de divergence persiste, et l'**onboarding d'une recrue est long**. Time-to-market dégradé.
- **Recommandation** : un **sprint de consolidation dédié** (décision officielle des modules legacy à retirer, traitement par lots de la baseline) **avant** d'ajouter des fonctionnalités.

2.5 ● Tests : forte couverture mais « fausse confiance verte » sur les zones sensibles

Le CI est mature (audits de dépendances, PHPStan, Pint, couverture ≥ 80 %). **Mais** les deux jobs qui vérifient l'intégrité réelle (argent/RGPD sur MySQL, E2E par rôle) sont **non bloquants**, et la suite principale tourne sur SQLite sans clés étrangères.

- **Impact** : un pipeline « tout vert » peut masquer des régressions sur l'argent et la conformité — précisément là où une erreur coûte cher.
- **Recommandation** : rendre ces gates **bloquants** avant go-live ; exiger une suite E2E verte sur les deux parcours critiques (client & prestataire) comme critère **go/no-go**.

2.6 ● Conformité (RGPD / fiscal) : socle présent mais non « prouvé »

Les briques existent et fonctionnent (GDPR export/erasure, FEC/DGFIP, KYC/KYB), mais la conformité n'est **pas démontrée par une campagne de tests** sur données réelles.

- **Recommandation** : exiger une campagne de tests conformité documentée (export + erasure sur jeu PII) + runbooks incident avant d'accepter des clients réels.

2.7 ● Documentation abondante mais hétérogène

94 fichiers `.md` (~27 500 lignes) : runbooks, checklists, 2 ADR, CONTRIBUTING, 3 CHANGELOG — volume élevé pour un projet solo. **Mais** : contradictions internes (cf. 2.2), seulement 2 décisions d'architecture formalisées, **un seul tag de release** malgré ~600 commits.

- **Recommandation** : une **source de vérité unique** d'état projet ; versionnage sémantique avec tags par jalon ; étendre les ADR aux décisions structurantes (legacy vs v2).

3. Tableau de bord — santé du projet

Axe	Note /5	Justification
Code (qualité/architecture)	● 3,5	Bonne séparation services/contrôleurs ; mais baseline PHPStan gelée + dette legacy
Tests	● 3,0	CI riche ; gates argent/RGPD/E2E non bloquants, SQLite sans FK
Sécurité	● 3,5	Findings critiques corrigés, 2FA admin, secrets propres ; audit rôle-par-rôle à finir
Conformité (RGPD/fiscal)	● 3,0	Briques complètes ; non prouvée par tests/procédure
Documentation / gouvernance	● 3,0	Volume élevé + traçabilité audit→commit ; mais incohérences, 2 ADR, 1 tag
Équipe / continuité	● 1,0	Bus factor = 1. Aucun pair, aucune revue externe

Santé globale : ~6,5/10 (cohérent avec le 7,7/10 de l'audit *technique*, abaissé ici par le poids du risque humain/gouvernance).

4. Verdict & décisions de pilotage prioritaires

Projet techniquement avancé et réactif aux audits, mais pas encore mûr pour un go-live commercial. Les défauts ne sont plus techniques bloquants (les critiques sont corrigés) mais relèvent du **pilotage** : dépendance à une personne, écart promesse/réalité, validation terrain inachevée. Le cap à franchir est celui de l'**industrialisation**.

5 décisions prioritaires :

1. ● **Lever le bus factor** — recruter/associer un 2^e développeur senior, sécuriser accès/secrets/comptes. (*risque n°1*)
2. ● **Aligner le discours sur la réalité** — corriger le README, bannir « production-ready » jusqu'aux critères go-live remplis, trancher le nom de marque.
3. ● **Rendre bloquants les gates argent/RGPD/E2E** et exiger une suite E2E verte sur les parcours critiques (go/no-go).
4. ● **Lancer un sprint de consolidation legacy** (modules à retirer, baseline PHPStan, unification de schéma) avant d'ajouter des fonctionnalités.
5. ● **Prouver la conformité** (campagne de tests RGPD + runbooks incident) et planifier le sign-off des 12 items en quarantaine.

Documents de référence : [AUDIT-PLATEFORME-2026-06-08.md](#) , [AUDIT-FONCTIONNEL-PLATEFORME-2026-06-08.md](#) ,
[AUDIT-QUARANTINE-BATCH.md](#) , [CLEANUP_PLAN_PRODUCTION.md](#) , [GO_LIVE_CHECKLIST.md](#) , [README.md](#) ,
[.github/workflows/ci.yml](#) . Réserve : l'analyse git (contributeurs, commits) et la documentation ont été
examinées ; aucune information RH/contractuelle hors dépôt n'a été utilisée.